HACKATHON 226 – SPRINT TECHNIQUE PRÉ-HACKATHON 2026 · NOTE DE SÉCURITÉ

Messagerie souveraine de l'administration

Équipe : **FasoCrypt** · Université Aube Nouvelle, Bobo-Dioulasso · Dépôt : github.com/AkimM226/messagerie-souveraine

1. Menaces prises en compte et protections

Menace	Protection mise en place (testée)
Lecture des messages et fichiers par le serveur, son administrateur ou un voleur de la base	**Chiffrement de bout en bout** Olm/Megolm fait par Element (vodozemac), messages *et* pièces jointes. Le serveur stocke des blocs `m.room.encrypted` et des fichiers `application/octet-stream` sans nom. Il **refuse tout message en clair** dans un salon chiffré. Vérifié : une chaîne de contrôle est introuvable dans la copie complète de la base, les fichiers et les journaux (`scripts/verifier.sh`).
Interception du trafic	Contenu déjà chiffré ; **HTTPS partout** (Caddy, autorité interne). Synapse ↔ Keycloak sur le réseau interne Docker.
Personne non autorisée (inscription, intrus, compte non enrôlé)	Pas d'inscription ni de mot de passe local : connexion uniquement par Keycloak (OpenID Connect + PKCE). Synapse exige le rôle `agent` . Aucune fédération, aucun invité. API et consoles d'administration non exposées (403).
Vol ou devinette du mot de passe	**TOTP obligatoire** pour tous (contrôlé par Keycloak, pas par l'interface), **à chaque connexion** : aucune session réutilisée, même sur un poste partagé (la déconnexion ferme aussi la session Keycloak) ; blocage après 5 échecs ; limite de connexions par adresse côté Synapse.
Agent qui quitte son poste, appareil perdu	**Révocation centralisée et idempotente** : désactiver l'agent dans la console Keycloak suffit. Toutes les 5 s, le module `annuaire.py` relit l'annuaire et désactive le compte Matrix : jetons et appareils supprimés, départ de tous les groupes. Les autres appareils **changent de clé Megolm** : vérifié, le message suivant utilise une nouvelle session. Testé : sessions coupées en 1 à 5 s, sur deux appareils ; ancien jeton et reconnexion refusés.
Usurpation de rôle ou d'identité	Rôles vérifiés **par le serveur** : seul un `responsable` classifie un salon. Nom affiché imposé par l'annuaire (y compris par salon). Dans le circuit, seuls les membres de niveau ≥ 50 (niveau appliqué par Synapse) émettent.
Page tierce greffée sur une conversation	Dans un salon classifié, le seul widget autorisé est le circuit. Celui-ci ne reçoit d'Element que les événements du circuit, ne voit jamais les clés et ne s'affiche que dans la messagerie (en-tête CSP `frame-ancestors`).
Dépendance ou fuite vers l'étranger	Aucun service tiers : pas de serveur de clés matrix.org, d'intégrations, de visio externe, d'aperçus de liens, de statistiques ; pages Synapse sans image externe ; bibliothèque du widget hébergée localement.
Conservation excessive	Salons classifiés à **expiration automatique** ; ni déclassement, ni ouverture publique, ni classification rétroactive.
Perte de données, traçabilité	Sauvegarde / restauration testées. **Journal Keycloak** des enrôlements, révocations et connexions (30 jours), sans contenu.

2. Chiffrement et gestion des clés

Chaque appareil possède ses clés Olm (identité Curve25519/Ed25519), générées et conservées **dans le navigateur** ; le serveur ne publie que les clés publiques. Un message de groupe est chiffré avec une session Megolm (AES-256 + HMAC), envoyée à chaque appareil membre par un canal Olm. Après le départ d'un membre, l'émetteur crée une nouvelle session. Le widget du circuit n'a aucune clé : Element chiffre ses événements (instructions, accusés) comme des messages ordinaires. **L'équipe n'a écrit aucune ligne de cryptographie.**

3. Ce que le serveur voit malgré tout (métadonnées)

- Identifiants des agents, membres de chaque salon, expéditeur et **horodatage** de chaque événement, taille approximative des messages et des pièces jointes, identifiant de session Megolm.

- **Noms et sujets des salons** (dont le niveau de classification) et noms affichés (fonction, direction, ministère) : n'y mettre aucune information sensible.
- Appareils de chaque agent et leurs clés publiques ; **adresses IP** (Synapse : 1 jour ; journal Keycloak : 30 jours).
- Accusés de lecture automatiques et indications de saisie d'Element (non chiffrés) ; réactions emoji (interdites en salon classifié).

Réductions : présence désactivée ; annuaire et profils réservés aux agents connectés ; aucune fédération ; contenu d'un message supprimé effacé après 1 h ; le serveur ne distingue pas une instruction ou un accusé du circuit d'un message ordinaire ; aucun contenu, jeton ou clé privée dans les journaux.

4. Limites connues et améliorations en cours

Nous documentons ces limites et continuons de travailler à les réduire ; pour chacune, la piste suivie :

- **Après révocation**, ce qui était déjà déchiffré sur un appareil hors ligne y reste lisible → *effacement à distance des données locales à la reconnexion (bouton d'urgence).*
- Un appareil connecté **après** l'envoi d'un message ne peut pas le lire ; les clés locales sont protégées par le navigateur et le système → *sauvegarde des clés chiffrée, protégée par une phrase de récupération.*
- **Capture et photo d'écran** restent possibles (le filigrane identifie l'agent) ; les accusés du circuit ne sont pas une signature électronique → *application mobile bloquant les captures ; signature avec une infrastructure de clés de l'État.*
- **Administrateur malveillant** : il ne lit pas les messages passés mais pourrait ajouter un appareil à un compte (signalé par la vérification croisée d'Element) ; TOTP n'empêche pas l'hameçonnage en temps réel → *clés de sécurité WebAuthn, double validation des actions d'administration.*
- Révocation en ≤ 5 s par relecture de l'annuaire ; Keycloak en mode développement ; un seul serveur ; secrets de démonstration (`.env`) ; une sauvegarde contient des clés privées du serveur (à garder chiffrée, hors ligne) → *révocation instantanée par notification, déploiement de production (base dédiée, haute disponibilité), sauvegardes chiffrées automatiques.*